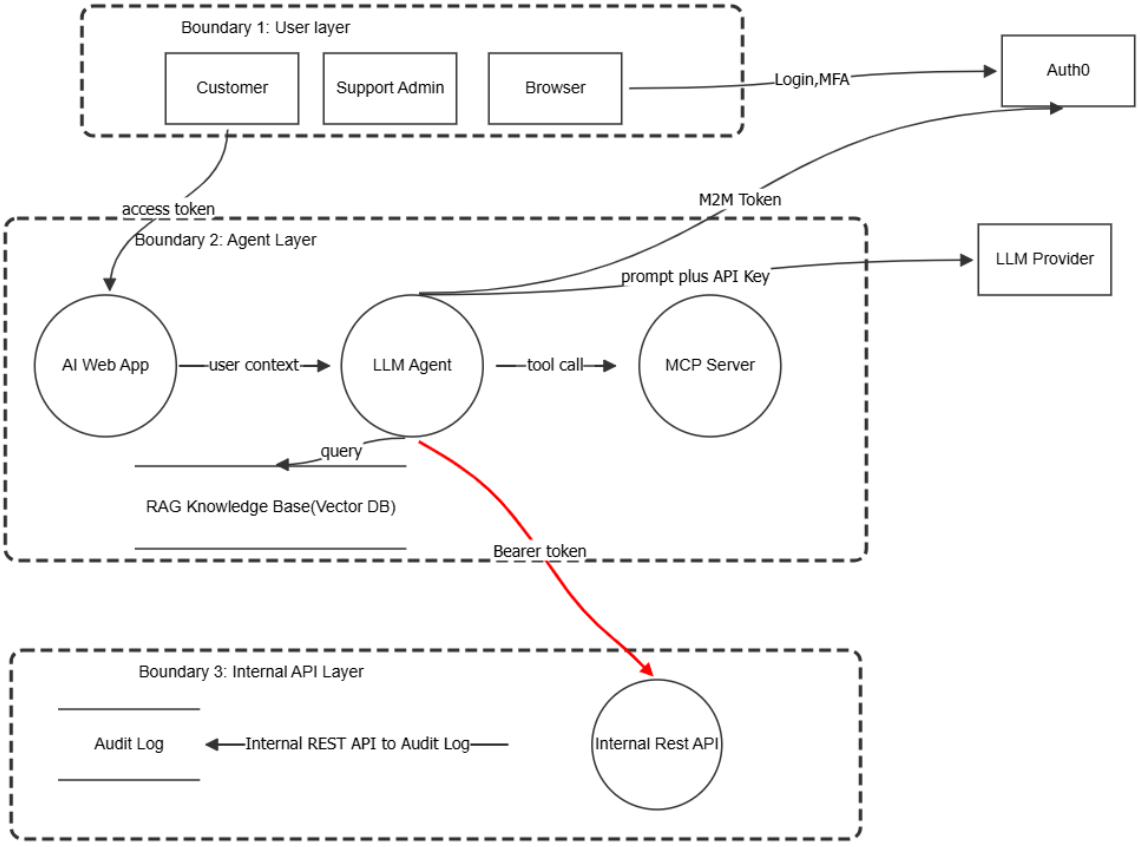
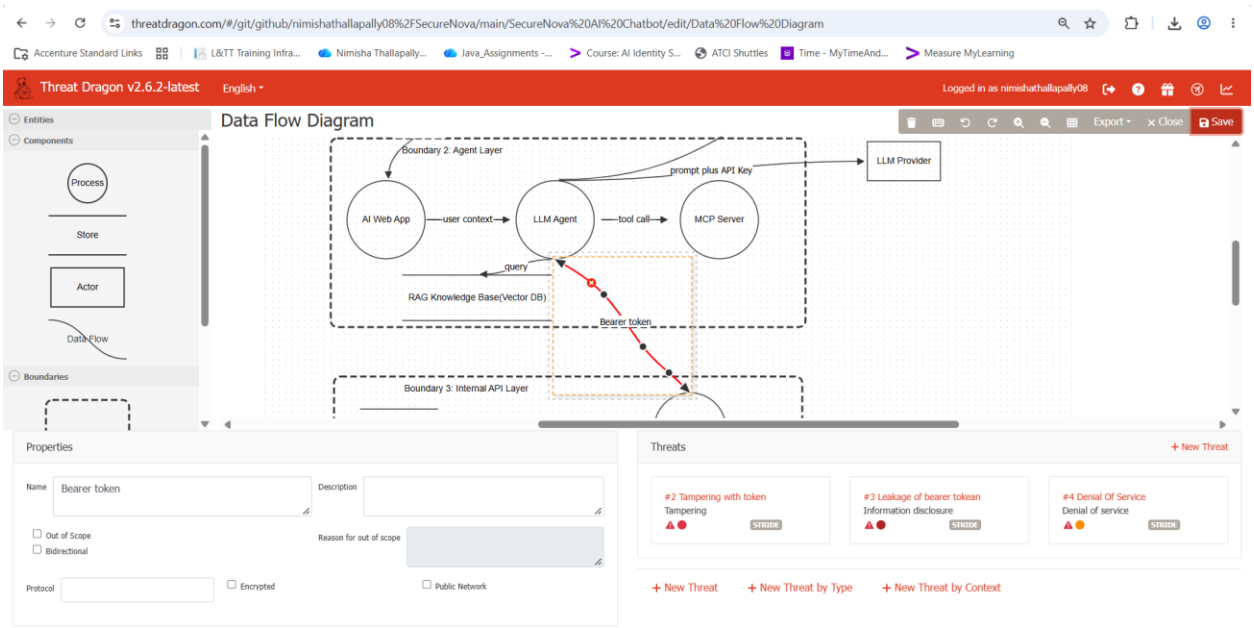
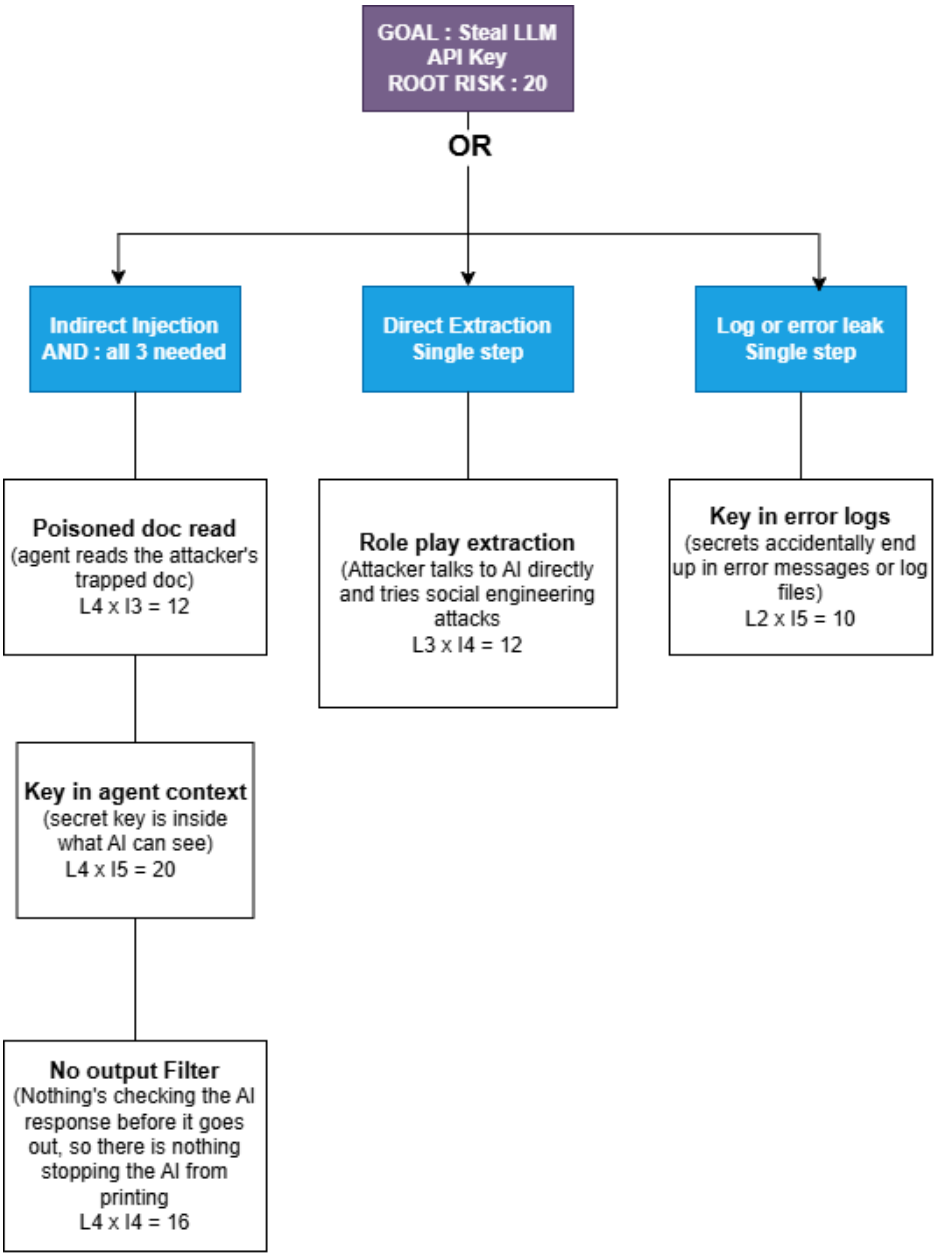
Project 1:



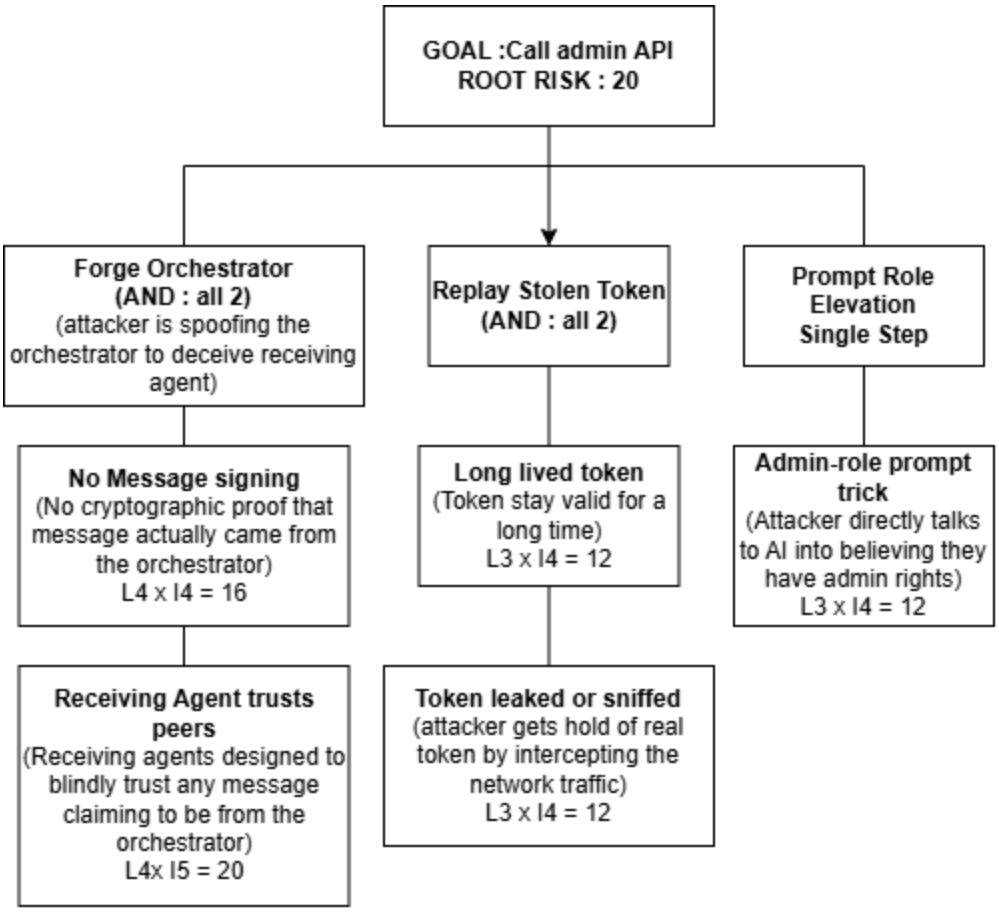
Caption: "OWASP Threat Dragon — complete data-flow diagram with identity components and the three trust boundaries (user layer, agent layer,internal API layer) labelled."



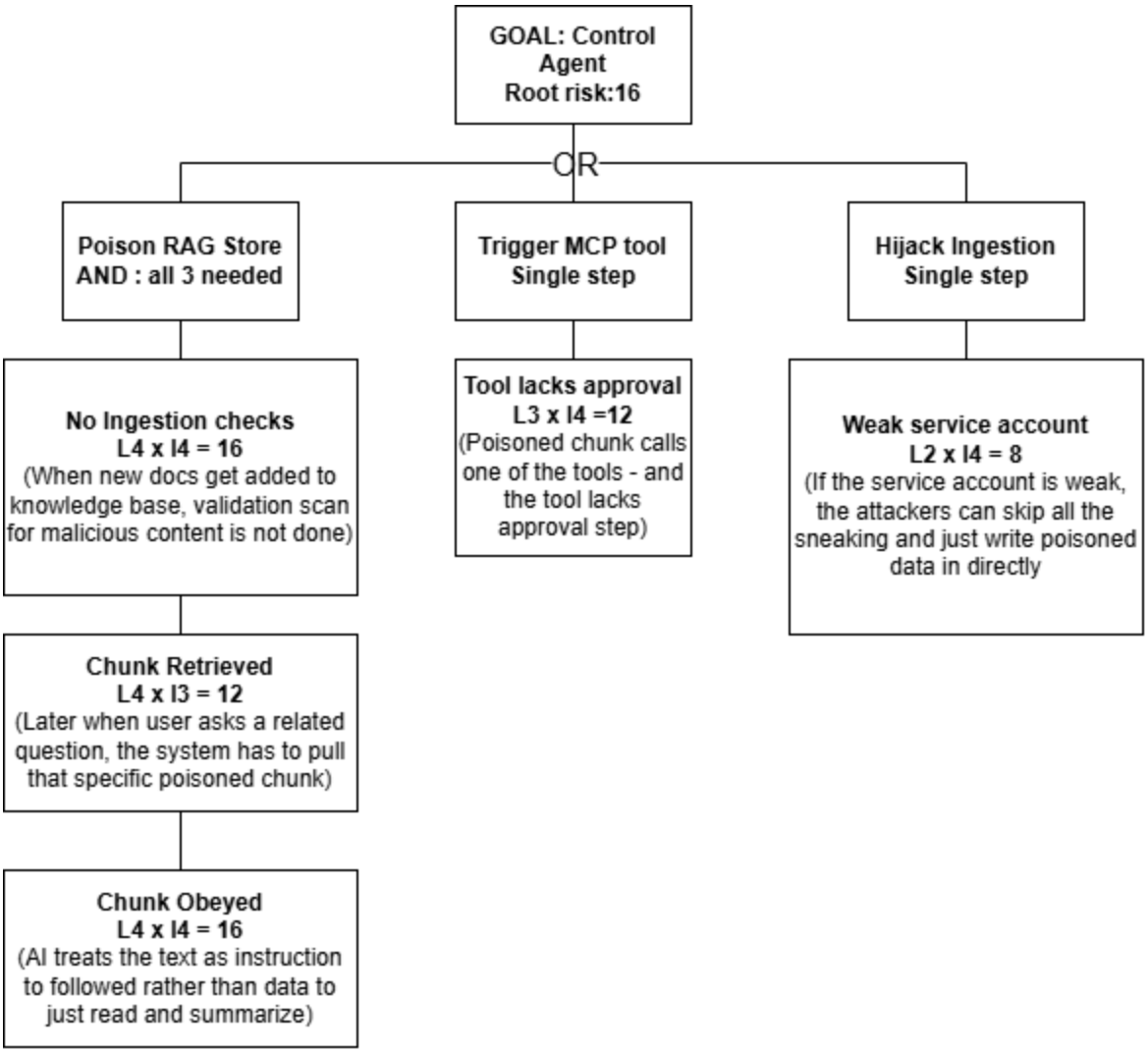
Caption: "Threat Dragon threat panel — at least 3 STRIDE threats populated for the LLM Agent to Internal API data flow."



Caption: "draw.io — Attack Tree 1 (LLM API key exfiltration), goal node and all branch/leaf nodes visible."



draw.io — Attack Tree 2: agent identity spoofing to gain elevated API scope. Goal node ("Call admin API") at top, with all OR/AND branches and leaf nodes visible, each scored by Likelihood × Impact.



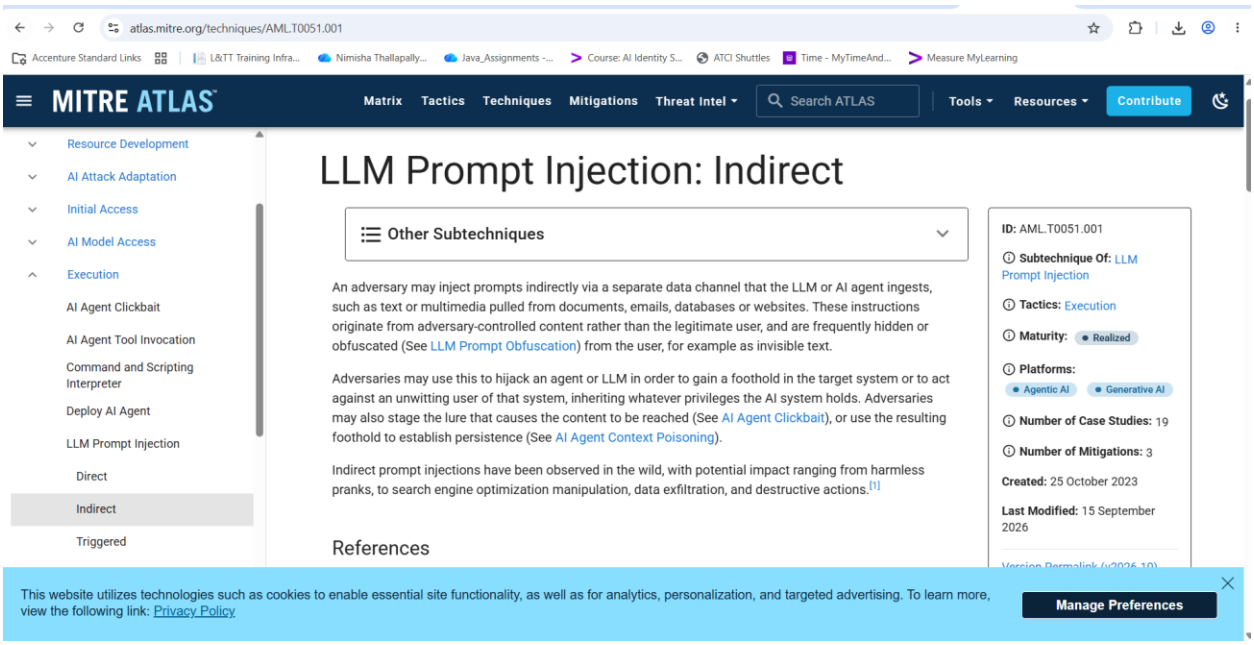
draw.io — Attack Tree 3: RAG chunk poisoning to manipulate agent behaviour. Goal node ("Control agent") at top, with all OR/AND branches and leaf nodes visible, each scored by Likelihood × Impact.

Data Flow	Spoofing (S)	Tampering (T)	Repudiation (R)	Information Disclosure (I)	Denial of Service (D)	Elevation of Privilege (E)
Customer -> Auth0 (login, MFA)	Credential stuffing against login form	Login request parameters altered in transit	Login attempt not tied to a verifiable session record	whether an email is registered	Login endpoint flooded with bogus attempts	MFA bypass grants unintended account access
Customer -> Chat App (access token)	Stolen access token reused by attacker	Token payload modified before reaching backend	No per-session log of which token issued which request	Token leaked via browser history or referrer header	Repeated token refresh requests exhaust rate limits	Token scope silently upgraded by a client-side bug
Chat App -> LLM Agent (user context)	Chat App impersonated by a rogue internal service	User context payload altered before reaching the agent	Agent actions not attributed back to originating chat session	Full user context, including PII, exposed in agent logs	Oversized context payloads degrade agent performance	Context injection elevates a customer session to admin-like behavior
LLM Agent -> Auth0 (M2M token)	M2M client credentials stolen and replayed	Token request parameters tampered in transit	Shared service credential used, no per-agent accountability	Client secret exposed in agent startup logs	Token endpoint flooded with M2M requests	M2M client granted broader scope than the agent needs
LLM Agent -> LLM Provider (prompt + API key)	Agent identity spoofed to call the LLM provider directly	Prompt content altered in transit to the provider	No log correlates a provider call with the originating user	Static API key exposed in the outbound request or logs	Excessive prompt volume causes LLM cost exhaustion	Agent uses a higher-privilege key than its task requires
LLM Agent <-> RAG Store (query / chunks)	Malicious actor impersonates the agent to query the RAG store	Retrieved chunk content altered or poisoned before use	No record of which chunks were retrieved for a given answer	Sensitive internal documents surfaced to unauthorized users	High-volume queries overload the vector database	Query crafted to retrieve chunks outside the agent's intended scope
LLM Agent -> MCP Server (tool call)	Forged orchestrator message spoofs a trusted tool caller	Tool call parameters modified before execution	Privileged tool call executed with no audit trail	Tool response leaks internal system details to the agent	Tool endpoint flooded with automated agent calls	Agent triggers a tool action beyond its granted scope
LLM Agent -> Internal REST API (Bearer token)	Forged or replayed agent identity calls the internal API	Request body or headers tampered in transit	Agent action not logged against a specific agent identity	JWT or response body leaks internal data to the model output	Internal API flooded with automated agent requests	Agent token used to call an admin-scoped endpoint
Internal REST API -> Audit Log	Log entries forged under a spoofed service identity	Log entries altered or deleted after being written	Critical actions never written to the log at all	Audit log exposes sensitive data to readers without need-to-know	Log write volume exhausts storage or write throughput	Logging service account granted write access beyond logging

STRIDE threat matrix — fully populated across all 9 identity data flows and all six STRIDE categories (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege).

ID	Threat	L	I	Score	Owner
R1	LLM API key leaked via indirect prompt injection	4	5	20	ML Engineering
R2	RAG poisoning triggers an MCP tool call	4	4	16	ML Engineering
R3	Agent identity spoofing escalates scope	3	5	15	IAM Team
R4	System prompt extraction reveals secrets	4	3	12	ML Engineering
R5	Stolen long-lived M2M token replayed	3	4	12	IAM Team
R6	Overprivileged agent scope	3	4	12	IAM Team
R7	Missing audit trail for agent actions	4	3	12	Platform Security
R8	Brute-force or credential stuffing on login	3	4	12	IAM Team
R9	JWT leaked in model output	3	4	12	Platform Security
R10	MFA bypass or fatigue	2	4	8	IAM Team
R11	Token endpoint DoS	2	3	6	Platform Security
R12	RAG ingestion credential compromise	2	4	8	Data Engineering

Risk register spreadsheet — all threats scored as Likelihood × Impact = Risk Score, sorted by score descending, with an owner assigned to each threat; 12 rows visible.



MITRE ATLAS (atlas.mitre.org) technique page for AML.T0051.001, LLM Prompt Injection: Indirect — the technique mapped to Attack Tree 1 (LLM API key exfiltration).